PES1UG24AM240-SE_Lab-5-Report

Name:SAIRAM CHARAN N

SRN:PES1UG24AM240

CLASS/SEC:-AiML/5-E

1. Executive Summary

This lab applied three static analysis tools to the Retail Point of Sale (POS) Python program: Pylint for code quality, Bandit for security-oriented checks, and Flake8 for style and formatting. The original source was analyzed before changes, findings were reviewed, and targeted corrections were made to the source file. The recorded results show an improvement in the Pylint score from 5.65/10 to 9.57/10, the three original Bandit findings no longer appearing in the later scan, and Flake8 producing no output after formatting corrections.

Pylint score	Bandit findings	Flake8 violations
5.65 → 9.57 / 10	3 → 0	5 → 0

2. Objectives

- Run static analysis on the assigned Python program without relying only on program execution.
- Identify code-quality, security, and formatting issues reported by Pylint, Bandit, and Flake8.
- Apply corrections and rerun the tools to compare before-and-after results.
- Maintain evidence through saved report files and three Git commits.

3. Project and Environment

The assigned project is a small Retail Point of Sale and Discount Tracker. The main source file is `pos_system.py`; it calculates checkout totals, applies promotional expressions, records receipt lines, and prints cumulative sales. Work was carried out in VS Code using a Python virtual environment on Windows.

Item	Details
Python	Python 3.12.6 (shown in the tool output)
Pylint	4.1.3
Bandit	1.9.4
Flake8	7.4.1

4. Tools and Their Purpose

Tool	Purpose	Role in this lab
Pylint	Checks Python code quality and programming practices.	Reports naming, docstring, unused-import, mutable-default,

		exception-handling, and other warnings.
Bandit	Scans Python source for common security risks.	Identified unsafe eval usage, use of random for a receipt number, and a try/except/pass pattern.
Flake8	Checks PEP 8 style and common formatting issues.	Reported unused imports, bare exception handling, line length, and blank-line violations.

5. Methodology

1. Cloned the assigned repository fork and opened it in VS Code.
2. Created and activated a Python virtual environment and installed Pylint, Bandit, and Flake8.
3. Ran the original program and generated the three before-analysis reports.
4. Reviewed findings and corrected the source in stages, beginning with Bandit security findings.
5. Reran the analysis tools and saved after-analysis reports.
6. Created three separate Git commits corresponding to security, code-quality, and formatting changes.

6. Findings and Corrections

Tool / finding	Before result	Correction applied	After result
Bandit B307 — eval()	Medium severity; high confidence	Replaced arbitrary expression evaluation with a constrained regular-expression parser for supported promo formats.	No issues identified in the later Bandit scan.
Bandit B311 — random	Low severity; high confidence	Used `secrets` to generate a four-digit receipt number.	No issues identified in the later Bandit scan.
Bandit B110 — try/except/pass	Low severity; high confidence	Removed the broad exception-and-silence pattern; validate input and log invalid requests.	No issues identified in the later Bandit scan.
Pylint quality findings	Score: 5.65/10	Removed unused imports, added docstrings, corrected naming/call references, fixed mutable default argument, and improved exception/file handling.	Recorded score: 9.57/10.
Flake8 style findings	Five reported blank-line violations in the later progress scan; original report also listed unused imports, bare except, line length, and unused variable.	Adjusted top-level blank lines and spacing; earlier code edits also addressed related issues.	Flake8 command produced no output.

Note: the Pylint screenshot showing 9.57/10 still displayed a module-docstring warning and a global-statement warning. The score met the lab target (>9.5), but these remaining messages should be described accurately rather than reported as fully eliminated.

7. Before-and-After Results

Measure	Before	After

Pylint score	5.65/10	9.57/10 (target > 9.5 achieved)
Bandit findings	3 total: 2 low, 1 medium	0 issues identified
Flake8 output	Multiple violations	No output on the final run

8. Git Commit History

Commit	Hash	Message
1	b96ac50	fix: address Bandit security findings
2	86bc1ff	refactor: improve Pylint code quality
3	9130552	style: fix Flake8 formatting issues

The commits were created locally and the user subsequently reported pushing the branch to GitHub. The repository link is https://github.com/acceptedsoul-11/L5_02_retail_pos.

9. Testing and Verification

The original program was run before modifications and its output was captured. Static verification after the changes showed a Bandit scan with no identified issues and a Flake8 run with no output. The recorded Pylint score was 9.57/10. A final functional run of the modified program should be performed before submission, especially for valid and invalid promotional inputs, invalid quantities, tax-rate validation, and receipt-file writing.

10. Conclusion

The lab demonstrated how static analysis can identify problems that may not be obvious during a normal run. Bandit guided security improvements, Pylint helped raise the code-quality score above the required threshold, and Flake8 helped standardize formatting. Keeping before-and-after reports and separate commits provides a traceable record of the work. Static analysis complements, but does not replace, functional testing.

Appendix A — Evidence to Include

- Original program run and the three before-analysis reports.
- Bandit after scan showing “No issues identified.”
- Pylint after report showing 9.57/10.
- Flake8 after run showing no output.
- GitHub commit history showing all three commits.
- Final repository listing with source, six reports, issues table, reflection, and this report.

Appendix B — Color Scheme

Color	Hex code	Usage
Deep Navy	#17324D	Main title, section headings, table headers
Teal	#168C8C	Accent headings, labels, highlights
Pale Blue	#EAF3F7	Metadata panels and soft backgrounds
Light Teal	#E5F4F2	Result highlight cells
Slate	#4B5B68	Body text

Appendix C — Screenshot Evidence

The following screenshots are retained from the supplied evidence document and arranged in their original appearance order. They document repository setup, source discovery, tool installation, baseline reports, fixes, analysis results, and Git commits.

Evidence 01

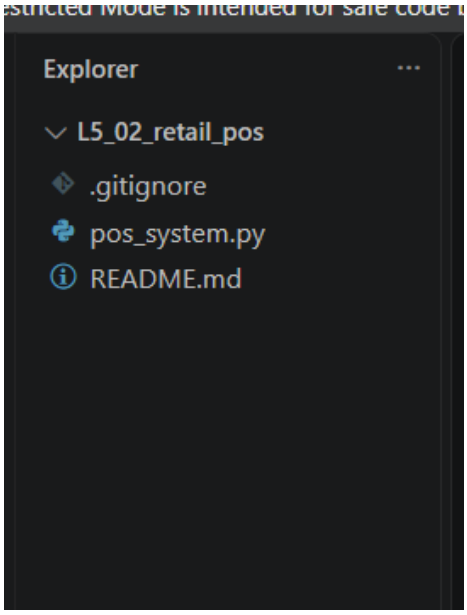
Original image: image13.png • 1161 × 253 px

```
Microsoft Windows [Version 10.0.26200.9711]
(c) Microsoft Corporation. All rights reserved.

C:\Users\saira>git clone https://github.com/acceptedsoul-11/L5_02_retail_pos.git
Cloning into 'L5_02_retail_pos'...
remote: Enumerating objects: 5, done.
remote: Counting objects: 100% (5/5), done.
remote: Compressing objects: 100% (4/4), done.
remote: Total 5 (delta 0), reused 5 (delta 0), pack-reused 0 (from 0)
Receiving objects: 100% (5/5), done.
```

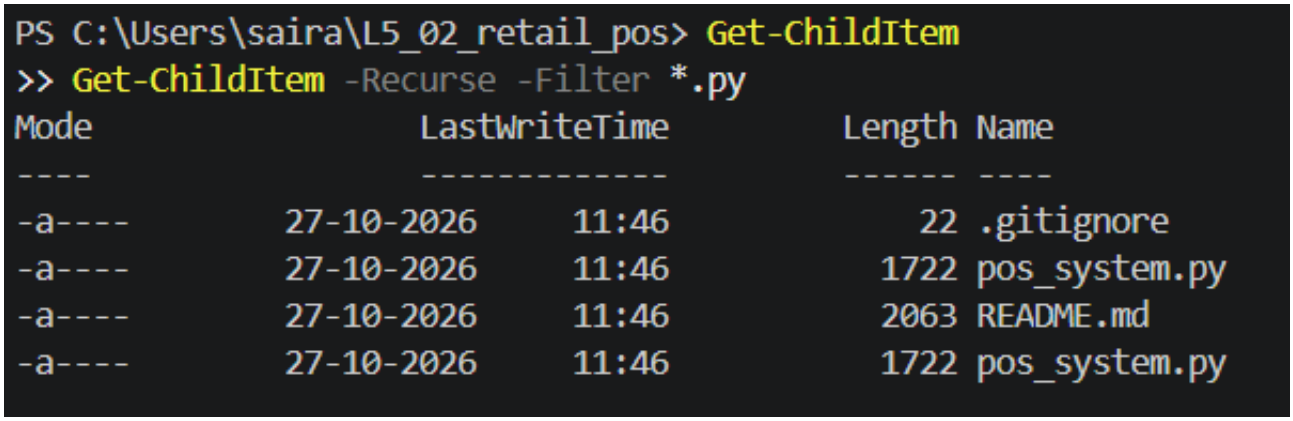
Evidence 02

Original image: image7.png • 271 × 357 px



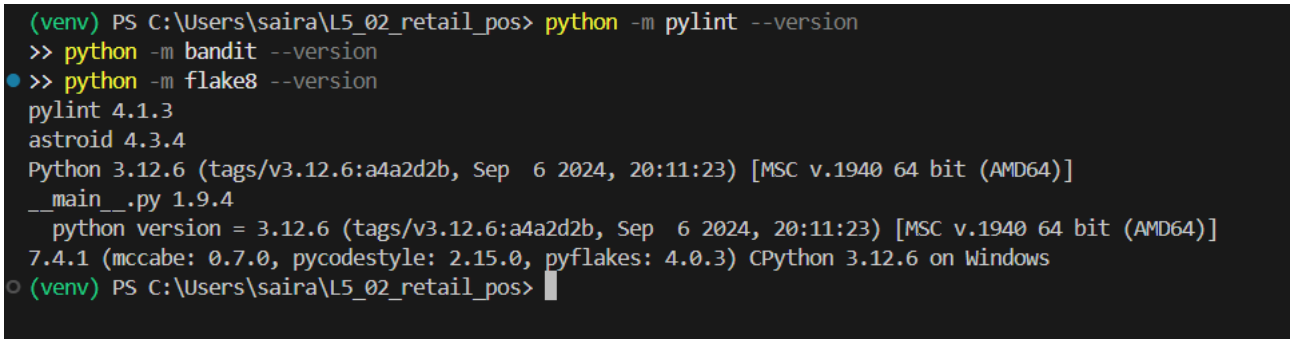
Evidence 03

Original image: image12.png • 602 × 193 px



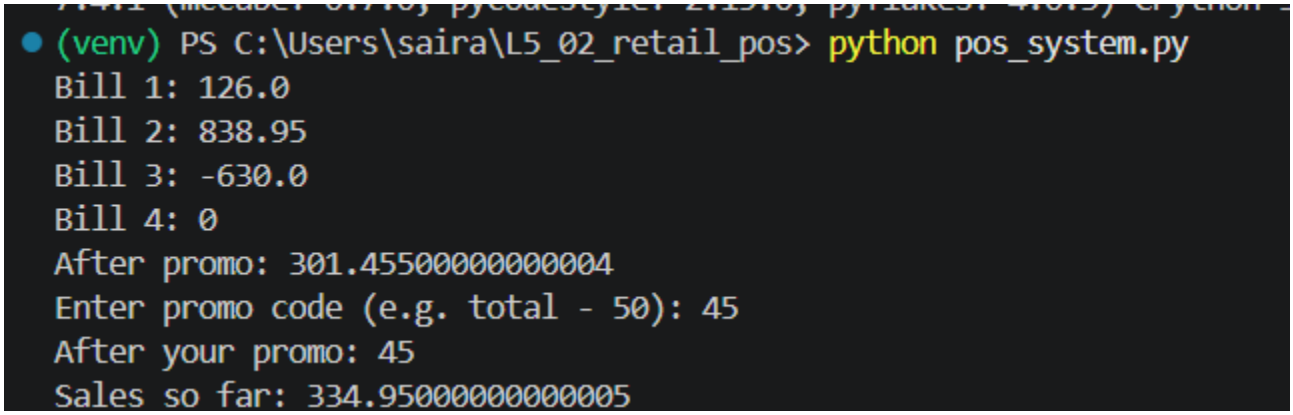
Evidence 04

Original image: image16.png • 963 × 250 px



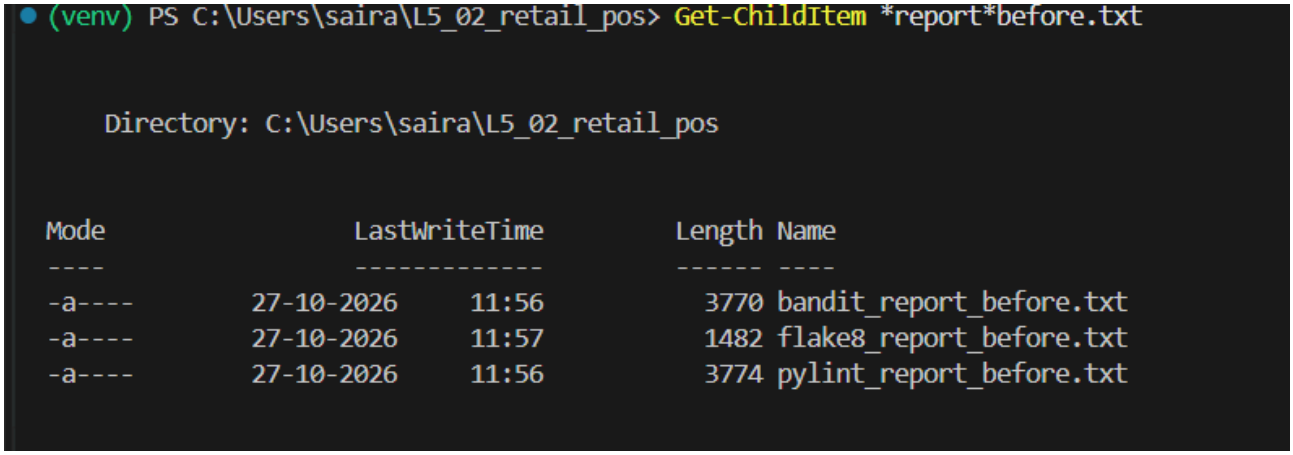
Evidence 05

Original image: image9.png • 643 × 203 px



Evidence 06

Original image: image10.png • 792 × 275 px



Evidence 07

Original image: image19.png • 1097 × 532 px

```
(venv) PS C:\Users\saira\L5_02_retail_pos> Get-Content pylint_report_before.txt
pos_system.py:1:0: C0114: Missing module docstring (missing-module-docstring)
pos_system.py:7:0: C0103: Constant name "sales_total" doesn't conform to UPPER_CASE naming style (invalid-name)
pos_system.py:10:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:10:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
pos_system.py:11:4: W0603: Using the global statement (global-statement)
pos_system.py:16:8: W0702: No exception type(s) specified (bare-except)
pos_system.py:21:25: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
pos_system.py:24:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:27:11: W0123: Use of eval (eval-used)
pos_system.py:26:4: W0612: Unused variable 'total' (unused-variable)
pos_system.py:29:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:33:11: W0718: Catching too general exception Exception (broad-exception-caught)
pos_system.py:36:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:37:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
pos_system.py:37:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
pos_system.py:41:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:41:0: C0103: Function name "printSales" doesn't conform to snake_case naming style (invalid-name)
pos_system.py:44:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:1:0: W0611: Unused import json (unused-import)
pos_system.py:3:0: W0611: Unused import logging (unused-import)

-----------------------------------
Your code has been rated at 5.65/10
```

Evidence 08

Original image: image4.png • 1062 × 495 px

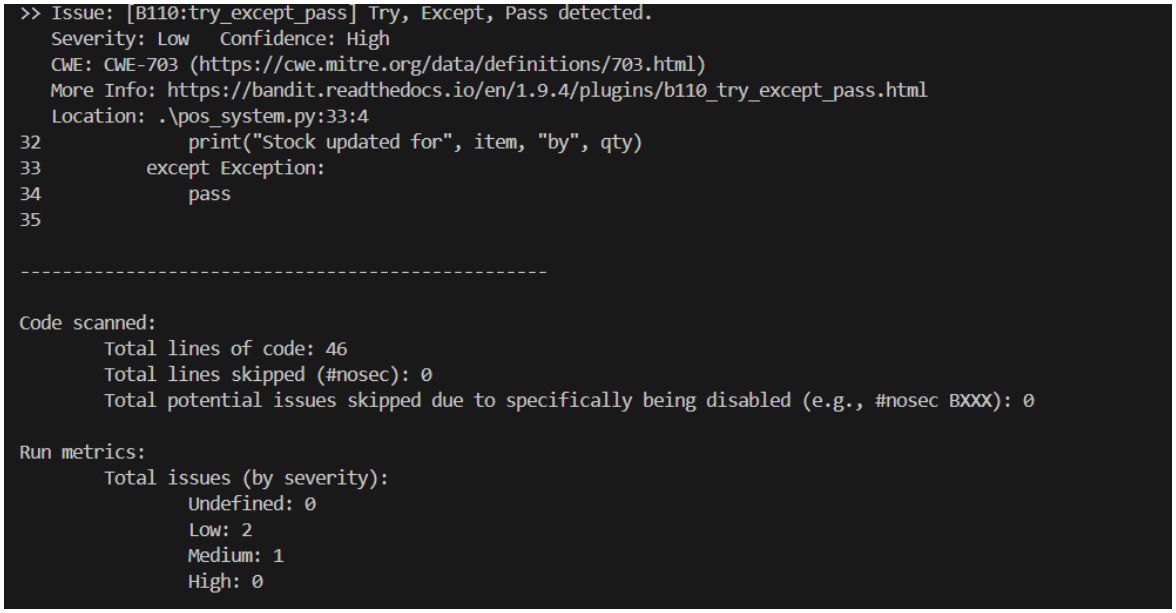
```
(venv) PS C:\Users\saira\L5_02_retail_pos> Get-Content bandit_report_before.txt
Run started:2026-10-27 06:26:57.748060+00:00

Test results:
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\pos_system.py:21:53
20          sales_total += total
21          receipt_lines.append("Receipt #%d total=%.2f" % (random.randint(1000, 9999), total))
22          return total

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\pos_system.py:27:11
26          total = sales_total
27          return eval(code_str)
28
```

Evidence 09

Original image: image18.png • 995 × 515 px



```
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\pos_system.py:33:4
32              print("Stock updated for", item, "by", qty)
33          except Exception:
34              pass
35

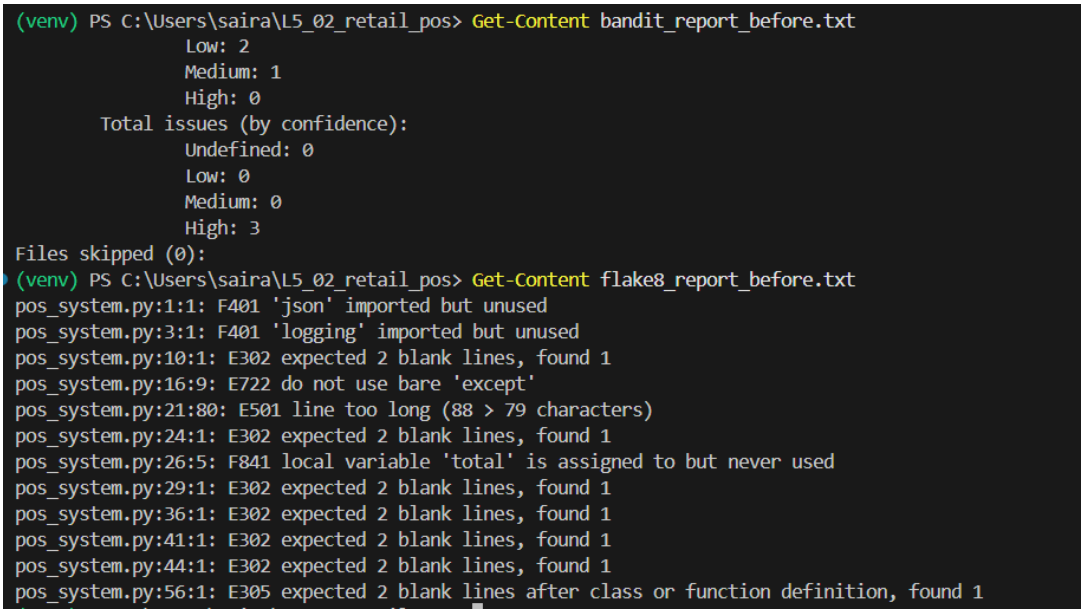
--------------------------------------------------

Code scanned:
        Total lines of code: 46
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 0
```

Evidence 10

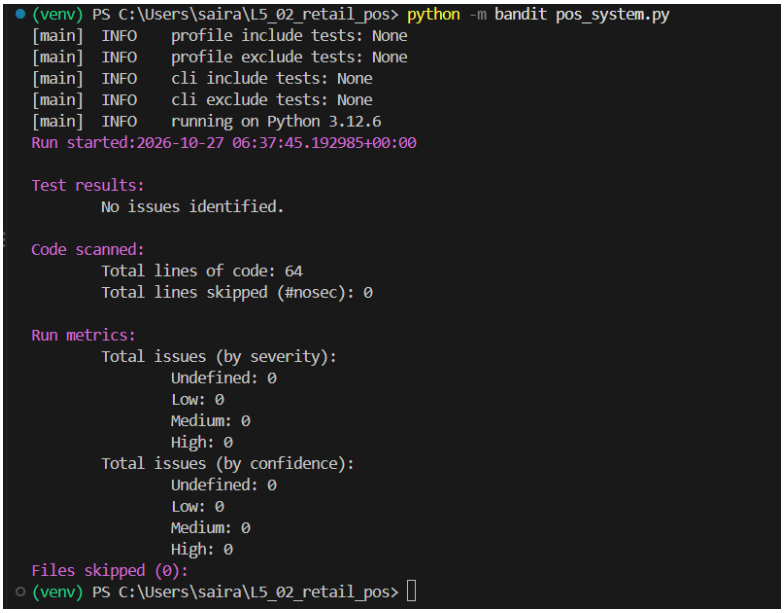
Original image: image15.png • 912 × 512 px



```
(venv) PS C:\Users\saira\L5_02_retail_pos> Get-Content bandit_report_before.txt
                Low: 2
                Medium: 1
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 3
Files skipped (0):
(venv) PS C:\Users\saira\L5_02_retail_pos> Get-Content flake8_report_before.txt
pos_system.py:1:1: F401 'json' imported but unused
pos_system.py:3:1: F401 'logging' imported but unused
pos_system.py:10:1: E302 expected 2 blank lines, found 1
pos_system.py:16:9: E722 do not use bare 'except'
pos_system.py:21:80: E501 line too long (88 > 79 characters)
pos_system.py:24:1: E302 expected 2 blank lines, found 1
pos_system.py:26:5: F841 local variable 'total' is assigned to but never used
pos_system.py:29:1: E302 expected 2 blank lines, found 1
pos_system.py:36:1: E302 expected 2 blank lines, found 1
pos_system.py:41:1: E302 expected 2 blank lines, found 1
pos_system.py:44:1: E302 expected 2 blank lines, found 1
pos_system.py:56:1: E305 expected 2 blank lines after class or function definition, found 1
```

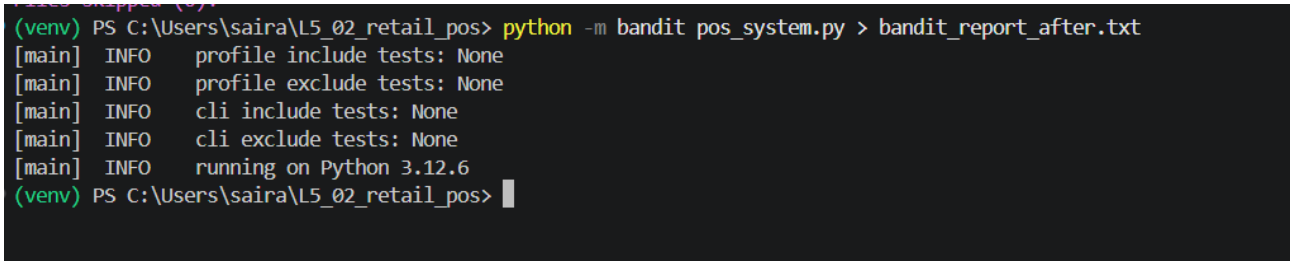
Evidence 11

Original image: image3.png • 801 × 622 px



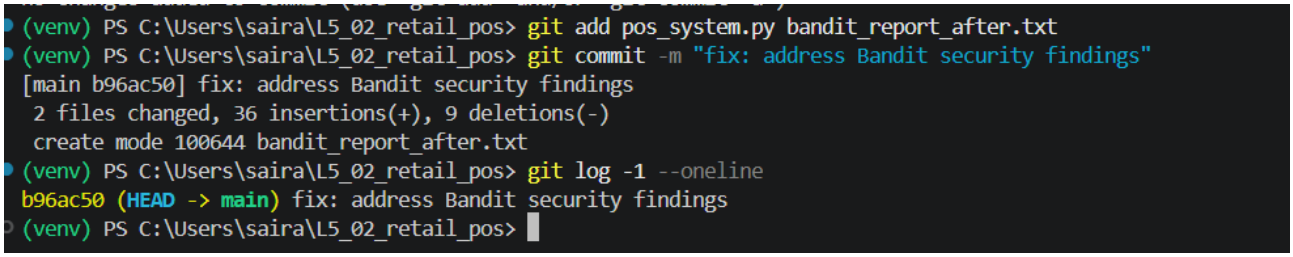
Evidence 12

Original image: image17.png • 1016 × 202 px



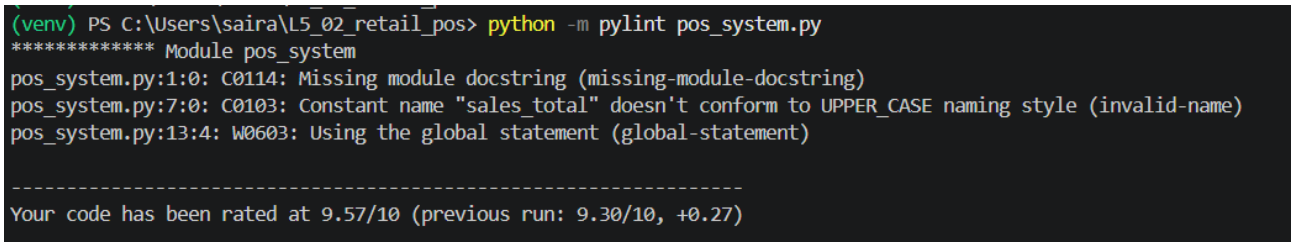
Evidence 13

Original image: image1.png • 983 × 190 px



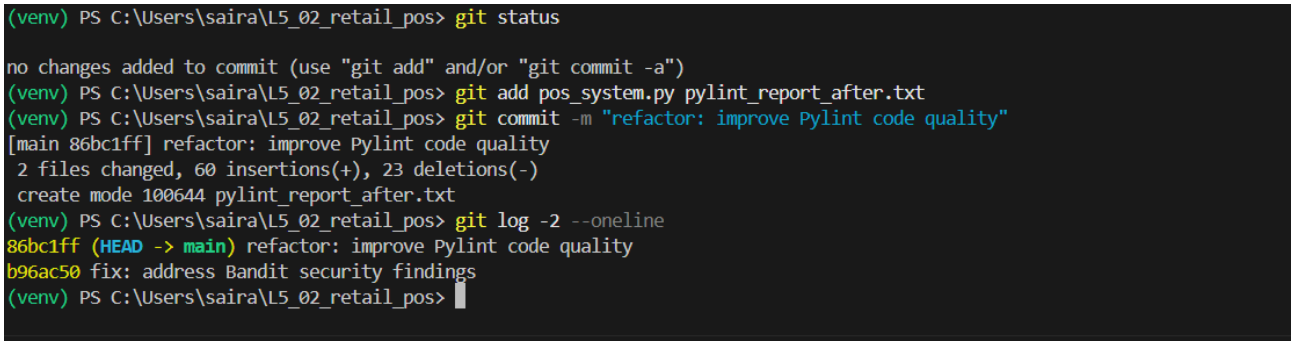
Evidence 14

Original image: image8.png • 1043 × 192 px



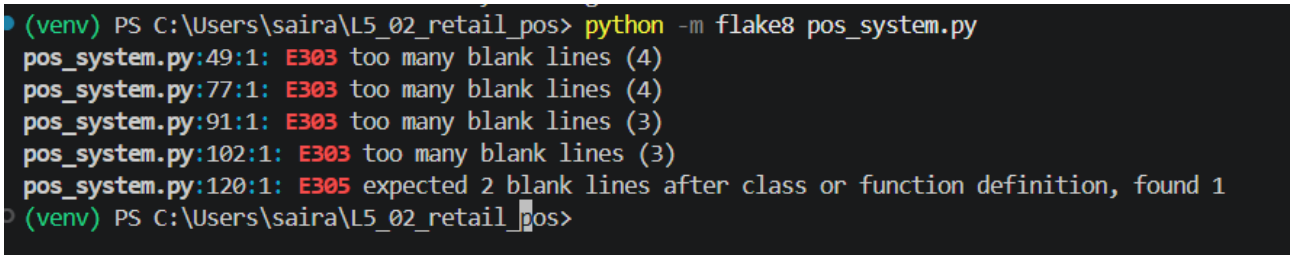
Evidence 15

Original image: image5.png • 1110 × 290 px



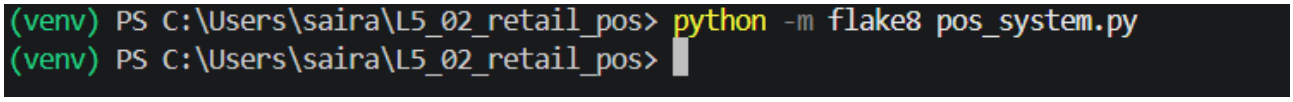
Evidence 16

Original image: image11.png • 886 × 172 px



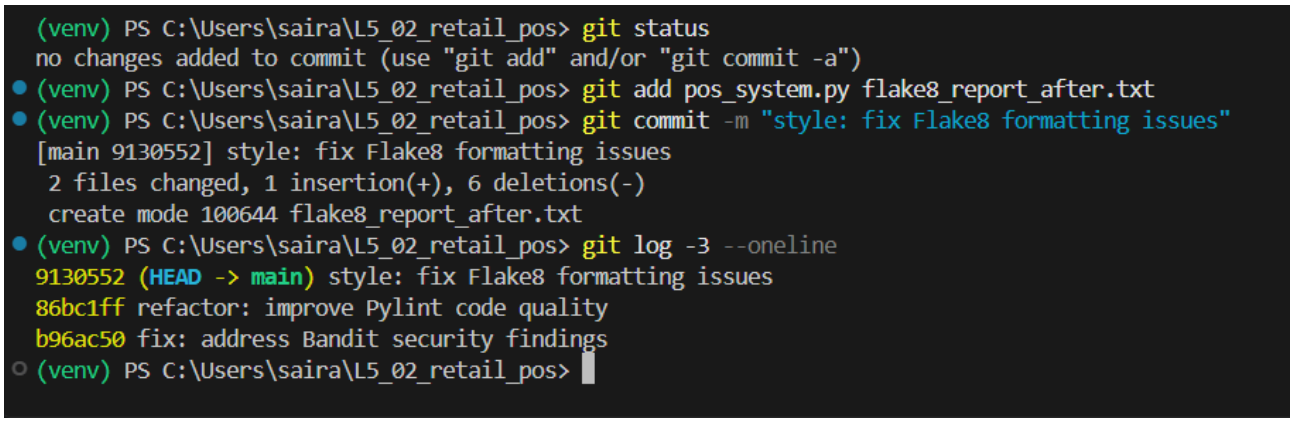
Evidence 17

Original image: image6.png • 748 × 53 px



Evidence 18

Original image: image2.png • 910 × 291 px



Evidence 19

Original image: image14.png • 1808 × 823 px

